

ATO Copilot

AI triage for ATO / NTAP governance workflows.

Arsen Khanguieldyan

arsen.khanguieldyan@gmail.com

Portfolio piece for State Street

OPEN THE LIVE DEMO

ato-copilot.up.railway.app

Source code github.com/smartpneucontact-sketch/ATO_Copilot

Model Anthropic Claude Sonnet 4.6 · ~\$0.07 per request

SUMMARY

ATO Copilot is a working portfolio demo aligned to the State Street ATO AI Process and Automation Engineer (AVP) role. A delivery team's free-text NTAP / ATO request goes in. A structured ATO package comes out — Approved Technology List check, NIST 800-53 control mapping, reference-architecture review, risk classification, cycle-time estimate, recommended decision (ATO-APPROVED / CONDITIONS / DENIED / ARB-ROUTING). Every claim cited back to a retrieved governance document. The agent loop and corpus contract map cleanly onto a Microsoft Copilot Studio + ServiceNow + Flexera production deployment.

THE PROBLEM THIS SOLVES

Enterprise ATO/NTAP processing today is a queue. Submissions sit waiting for a human reviewer to manually check the ATL, identify applicable controls, walk the reference architecture, classify risk, and route. Cycle times of 5–20 days are typical; cycle-time improvement is one of the State Street JD's named KPIs. The work is high-volume, citation-bound, and procedurally regular — the textbook shape of an AI-augmented governance workflow.

WHAT IT SHIPS

- Single AI agent (ATOResponseAgent) that runs a tool-use loop on Claude Sonnet 4.6: retrieve governance corpus, classify risk, estimate cycle time, then draft the structured ATO package.
- Synthetic but realistic governance corpus: 3 ATL entries (PostgreSQL/RDS, Kafka/MSK, Azure OpenAI), 2 NIST 800-53 control family summaries, reference architecture patterns with explicit anti-patterns, 2 prior ATO precedents (one Low + one High-risk).
- FastAPI service with visitor-notify (Resend HTTPS), modern dark UI with semantic rendering of every output field (ATL status, control mapping, risk badge, decision badge, cycle time, open items, rationale), deployed to Railway.
- Production-shape exactly: agent loop + tool-use ports to Copilot Studio with no code redesign; corpus contract maps to Azure AI Search over the existing SharePoint governance library; FastAPI surface ports to a ServiceNow / Power Automate workflow.

HOW IT MAPS TO STATE STREET'S STACK

Every component in this demo has a 1:1 production target. The agent loop and the corpus contract are the durable parts; the surfaces around them adapt to State Street's existing Microsoft / ServiceNow / Flexera footprint.

THIS DEMO	STATE STREET PRODUCTION
Anthropic SDK + Claude Sonnet 4.6	Microsoft Copilot Studio + Azure OpenAI (gpt-4o)
BM25 over markdown corpus	Azure AI Search / SharePoint Search on governance KB
FastAPI + Pydantic backend	ServiceNow workflow + Azure Function via Power Automate
Single-page HTML UI	ServiceNow service portal / Power Apps canvas
JSONL traces	Splunk + Azure Monitor
Synthetic ATL corpus	Flexera ITAM data + SharePoint ATL document library
YAML eval suite + GitHub Actions	Same — governance for the governance tool itself
Visitor-notify webhook	Power Automate flow → Outlook / Teams alert

SAMPLE AGENT REASONING (REAL RUN)

Example: a delivery team asks to upgrade PostgreSQL 14 → 16 on RDS for an internal reporting dashboard. Tool sequence is fully traced.

RUN_DEMO · 3 STEPS · INTERNAL DB UPGRADE REQUEST

```
step 0  retrieve(query="PostgreSQL RDS managed approved technology list",
               source_type="atl")
        -> atl:postgresql_rds                               (score 14.2)

step 0  retrieve(query="internal database approval prior ATO precedent",
               source_type="prior_ato")
        -> prior_ato:ato_0231                               (score 9.1)

step 0  classify_risk(handles_client_funds=false,
                    handles_pii_or_pci=false,
                    is_public_facing=false,
                    is_new_to_atl=false,
                    critical_business_function=false)
        -> risk_band="low", score=0

step 1  estimate_cycle_time(risk_band="low", is_new_to_atl=false,
                          needs_arb_review=false)
        -> estimated_days_to_decision=2

step 2  final answer (cited): ATO-APPROVED, low risk, 2-day cycle,
        no ARB review, inherits ATL-2024-DB-0017.
```

WHY THIS FITS THE ROLE

The JD asks for someone who modernizes, automates, and governs ATO/ATL lifecycle processes using workflow automation and AI-enabled capabilities. ATO Copilot is exactly that artifact: a real workflow-automation tool that compresses cycle time while preserving control rigor (citations, audit trail, ARB-routing flag). The agent pattern transfers trivially — same loop for vendor-risk intake, exception requests, control evidence collection, or recertification triage. Weeks not quarters.

HONEST GAPS

- Synthetic corpus, not real ATL / control catalogs. Real deployment needs the Flexera ITAM feed + SharePoint governance library and a refresh cadence.
- No ServiceNow / Power Platform integration yet — this is the FastAPI prototype demonstrating the pattern. The production wire is a custom connector behind an Azure Function.
- No human-in-the-loop UI for InfoSec / ARB reviewer to accept / edit / route the draft package — that's the next layer of UX work.
- Eval suite is shaped but not populated with a labeled golden set; production would need 100+ historical ATO decisions to score precision / recall on the recommendation field.

IN ONE LINE

Speed with safety — AI-triaged ATO/NTAP packages with full citation trail, shippable to a real governance workflow on the Microsoft + ServiceNow + Flexera stack State Street already runs.